COMISIÓN PARA EL MERCADO FINANCIERO

Regulador y Supervisor Financiero de Chile

Guía de ayuda rápida para pruebas en Sandbox ATENA SFA

Ambiente Tecnológico de Experimentación y Nuevas Aplicaciones

finanzasabiertas

COMISIÓN PARA EL MERCADO FINANCIERO

Marzo 2026

Pruebas de Acceso a Sandbox + Directorio

Objetivo General

El objetivo de las pruebas pre productivas es **validar, registrar y evidenciar** de forma trazable el proceso de acceso y **habilitación de los participantes al Sandbox Tecnológico, utilizando el Directorio** como mecanismo de registro y verificación.

A continuación, se indica qué artefactos se entregarán y el esperable de cada participante:

¿Qué se entrega a los Participantes?

- **Capacitaciones técnicas y operativas** previas al inicio de pruebas.
- **Accesos** al Sandbox Tecnológico y Directorio CMF (entorno pre-productivo).
- **Credenciales y certificados de prueba** (mTLS y firma).
- Documentación técnica y **manuales de acceso**.
- **Colecciones Postman** oficiales con endpoints, flujos FAPI y datos sintéticos.
- **Matriz de pruebas** donde se describa la acción esperada por el participante.
- **Canales de soporte** y coordinación durante la ejecución de pruebas

¿Qué se espera de los Participantes?

- **Ejecución de las pruebas** definidas en la matriz, dentro de los plazos asignados.
- **Registro completo y trazable de resultados y evidencias** (logs, capturas, exportaciones) en el formulario de JIRA.
- Cumplimiento de cuotas y límites operacionales del Sandbox.
- **Entrega de feedback** técnico sobre flujos, APIs y experiencia de integración dentro de los plazos asignados.
- Colaboración en instancias de cierre y lecciones aprendidas

Principios de Diseños y Flujos de Seguridad

Perfil de Seguridad

Objetivo y Enfoque:

Se establece un marco común de seguridad para la interacción de los participantes con el Portal del Desarrollador del Sistema de Finanzas Abiertas, alineado con estándares internacionales, que garantice control de accesos, integridad de la información y trazabilidad, de forma consistente en los distintos entornos operativos.

Mapa de Contenido:

Perfil de Seguridad FAPI2.0 versión Chilena

Define los requisitos mínimos de seguridad que deben cumplir todos los participantes del ecosistema adaptados a Chile, tomando como referencia el trabajo de los grupos técnicos

Rich Authorization Requests (RAR)

Establece los mecanismos para la expresión y control de consentimientos y alcances de acceso

Grant Management

Regula la administración del ciclo de vida de las autorizaciones otorgadas, incluyendo su emisión, uso y revocación

Casos de Error vinculados a Seguridad

Estandariza el tratamiento y comunicación de errores de seguridad, asegurando coherencia y trazabilidad

Dynamic Client Registration (DCR)

Define el proceso de registro dinámico de clientes, incorporando validaciones y controles de seguridad

Firma Digital de Mensajes y Payloads

Establece los lineamientos para la firma, verificación e integridad de los mensajes intercambiados

Especificación de Webhooks SFA

Regula el uso de notificaciones seguras asociadas a eventos relevantes del sistema

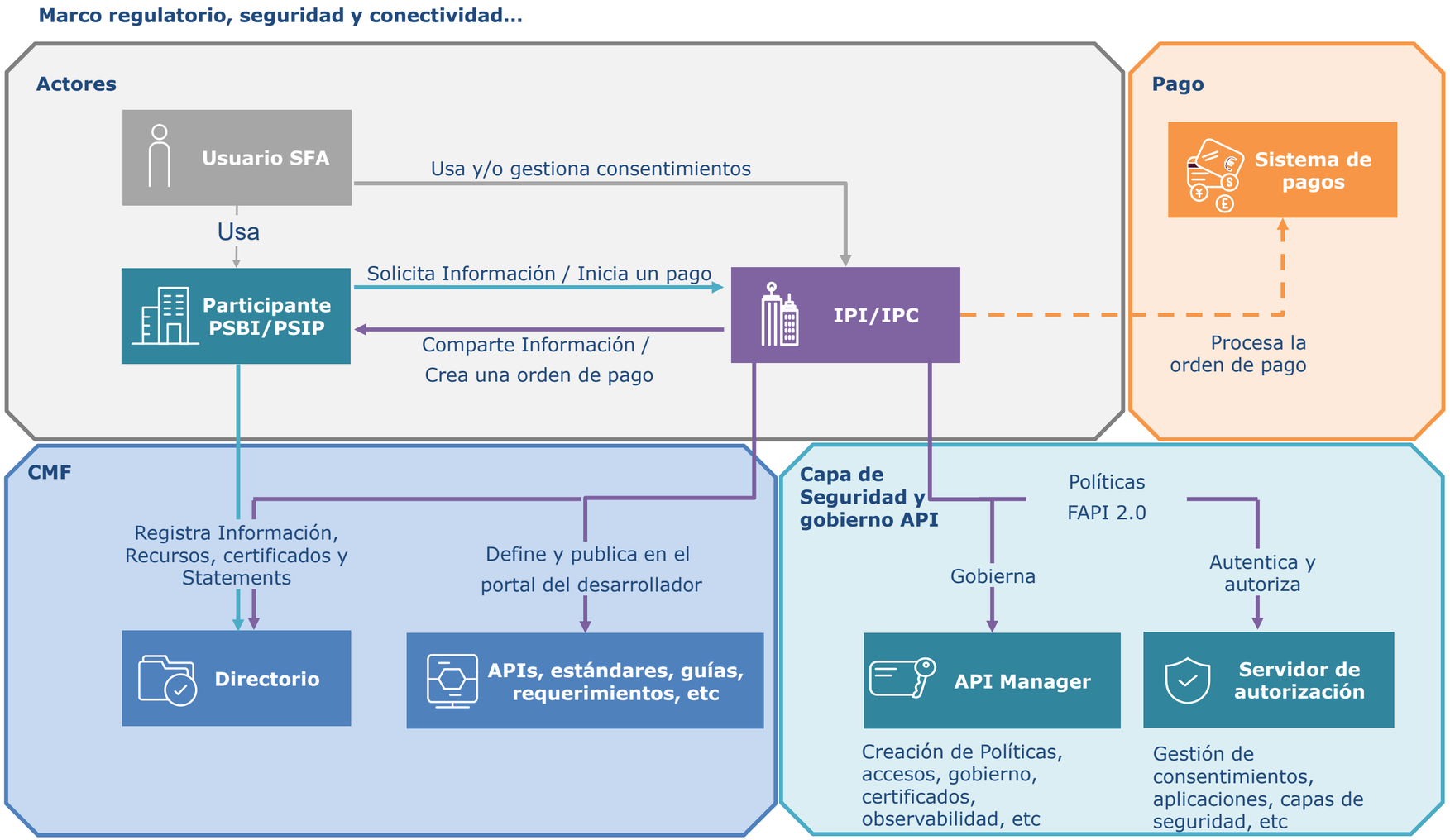
Reglas de Redirección Segura entre Aplicaciones

Define controles para garantizar redirecciones seguras, mitigando riesgos de uso indebido

Estos lineamientos establecen el marco común de seguridad del ecosistema; su implementación técnica detallada se encuentra disponible en el Portal del Desarrollador

Arquitectura ATENA SFA

Ecosistema de Finanzas Abiertas



Pruebas de Acceso a Sandbox + Directorio

Tipos de pruebas por Rol Participante

Para facilitar su ejecución, los tipos de pruebas se divide por rol participante:

Pruebas Rol IPI / IPC

- **Onboarding y habilitación de entidad**
- **Sincronización con el Directorio Certificados y conectividad segura** (mTLS / firma)
- **Exposición de capacidades de seguridad del AS** (metadata OIDC/OAuth y endpoints)

Pruebas con externos

- **Registro dinámico de clientes (DCR)** (Validación de integración para SSA)
- **Consentimiento y Grant Management** (creación, estados y control del acceso)
- **Exposición/ejecución de APIs** (respuestas y errores estándar)
- **Revocación y bloqueo posterior de acceso**

Pruebas Rol PSBI / PSIP

- **Onboarding y habilitación de entidad**
- **Configuración en Directorio** (datos del participante + callbacks/redirects + metadata)
- **Certificados y conectividad segura** (mTLS / firma)
- **Declaración de software (SSA) + JWKS**
- **Registro dinámico de clientes (DCR)** (registro del cliente en AS).
- **Autenticación y obtención de tokens** (flujo end-to-end)
- **Configuración Flujo PAR**
- **Consumo de APIs en Sandbox** (con token válido)
- **Revocación y validación de acceso denegado**
- **Límites operacionales y manejo de tráfico**

Los casos de prueba van enfocados netamente al acceso y se ejecutarán en Sandbox Pre-Productivo y Directorio, registrando evidencias y métricas de resultado por rol

Pruebas de Acceso a ATENA

Canales de Soporte y Registro de Evidencia

- Para facilitar las comunicaciones entre Participantes y el equipo CMF, se pondrá a disposición un canal oficial de contacto: https://cmfchile.atlassian.net/servicedesk/customer/portal/74

- Este canal está configurado sobre la plataforma de gestión de tareas de Jira Service Management, permitiendo así alcanzar altos estándares en el seguimiento, control y trazabilidad de las consultas.

- Los Participantes podrán realizar consultas funcionales, técnicas y también subir la documentación respectiva de las evidencias de cada prueba realizada.

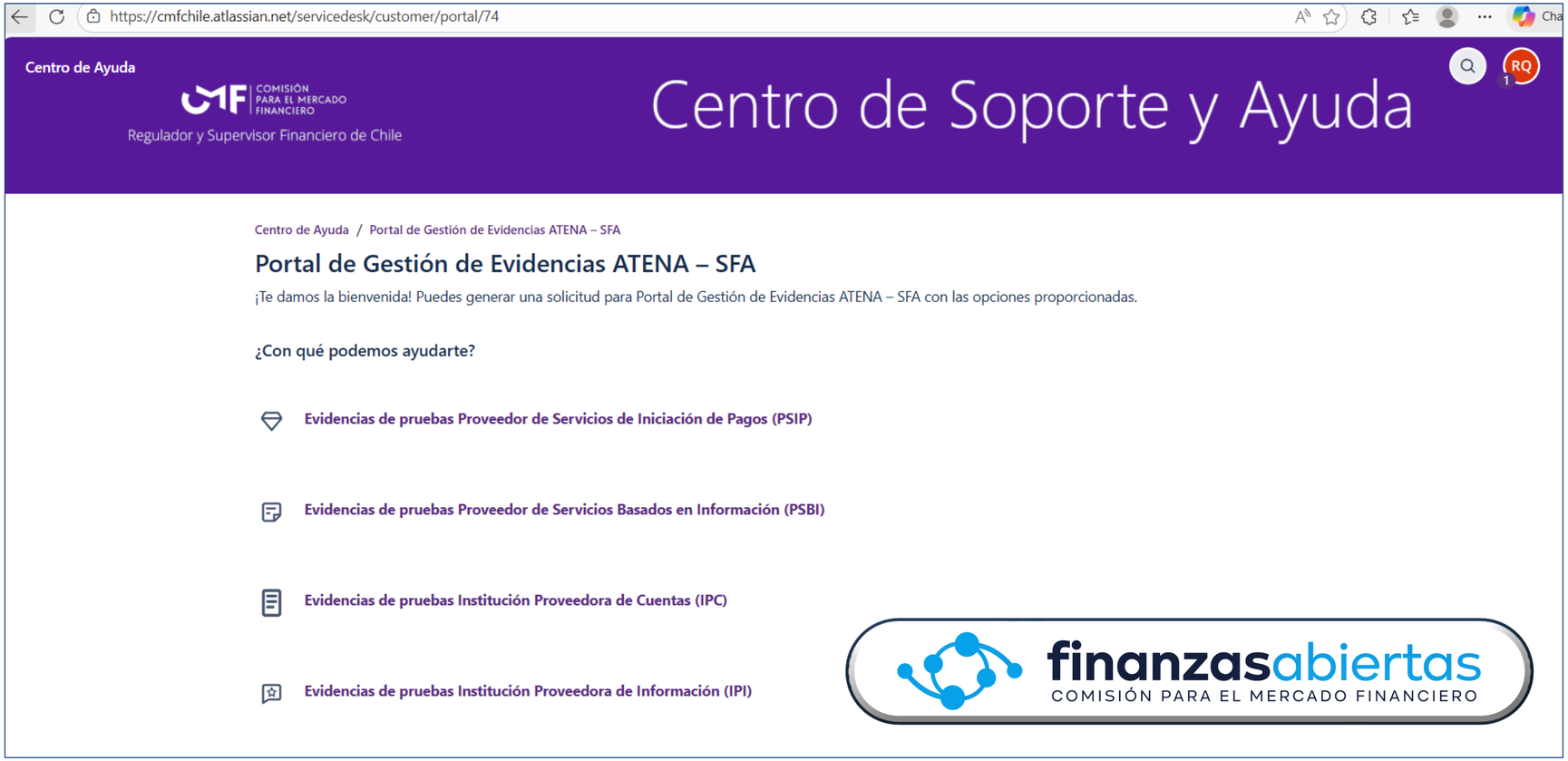


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

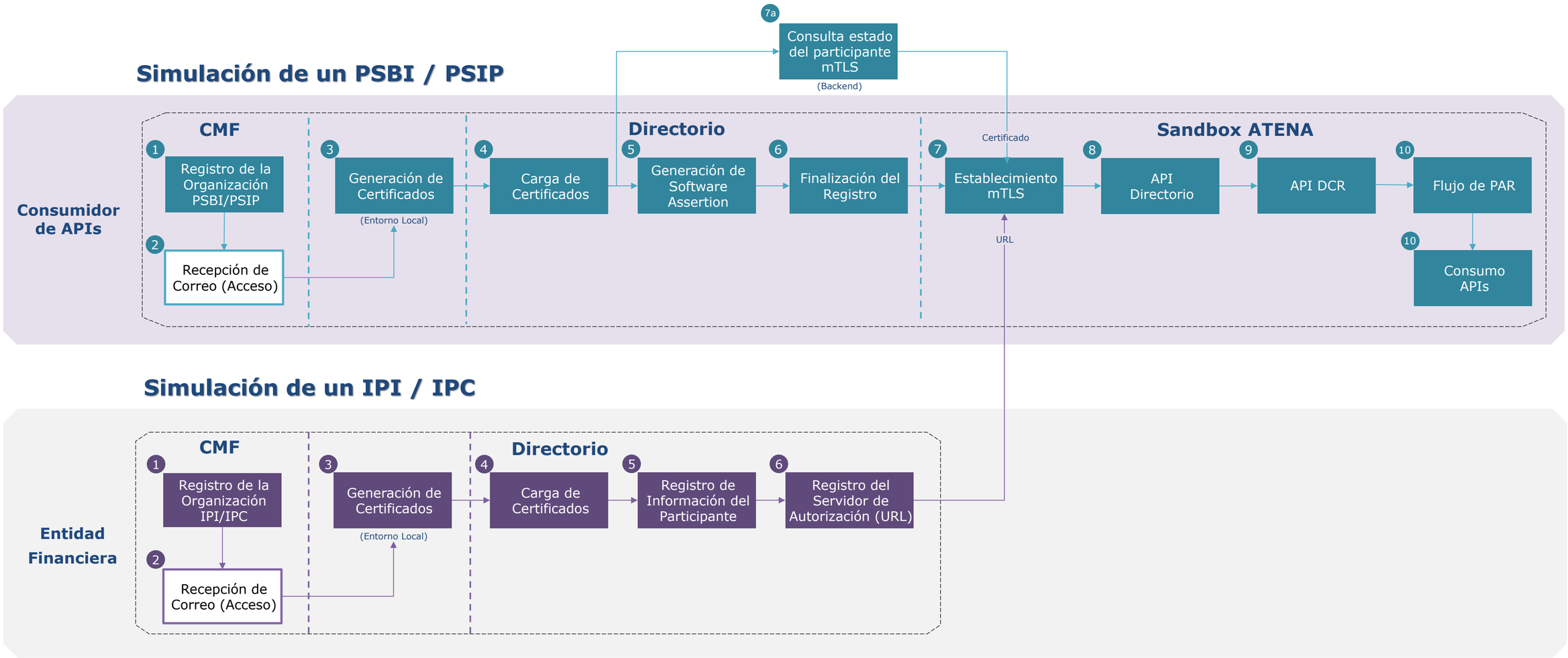


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- Para el flujo de un PSBI/PSIP, el primer paso es completar la información del Participante en el Directorio SFA, ej: datos del Participante, redirect URIs/callbacks, metadata y endpoints JWKS.
- El Participante deberá darse de alta en el Directorio pre-productivo en el siguiente link https://directorio-qa.finanzasabiertas.cl/auth/login

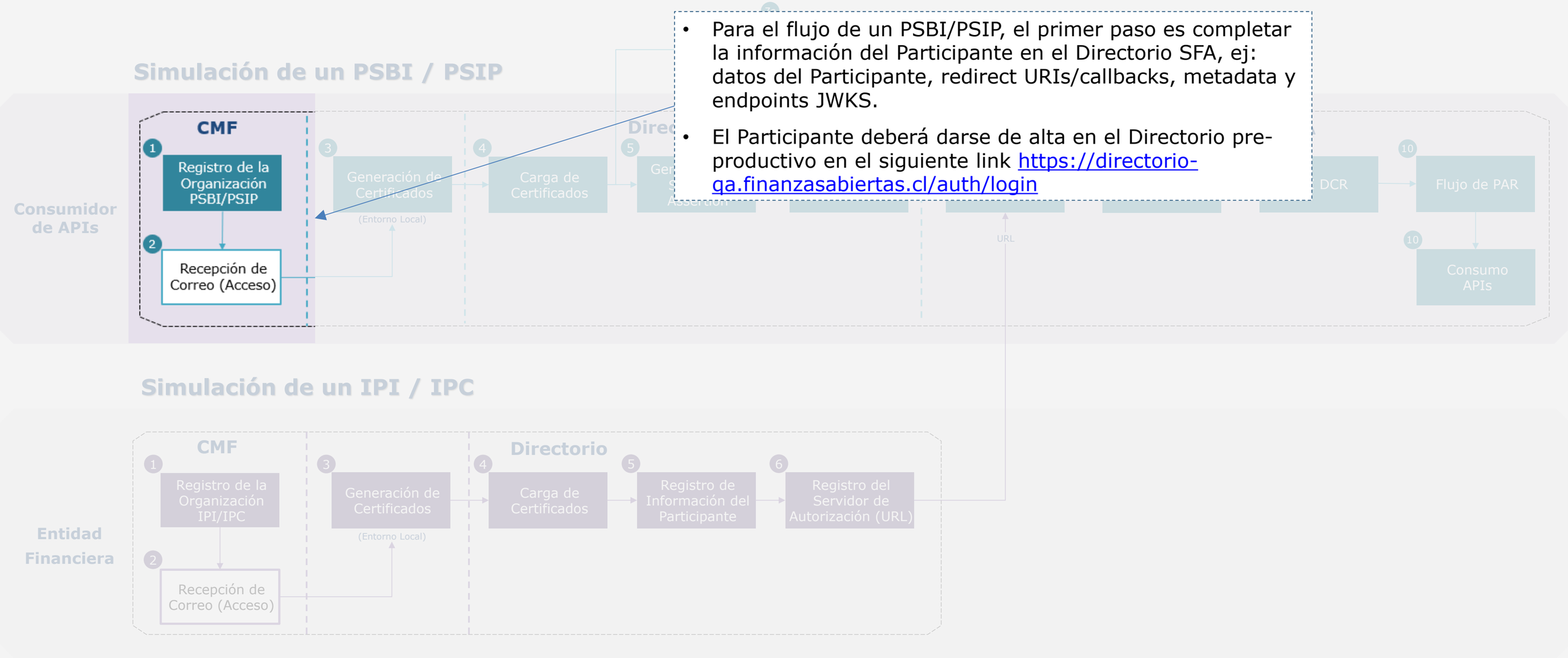
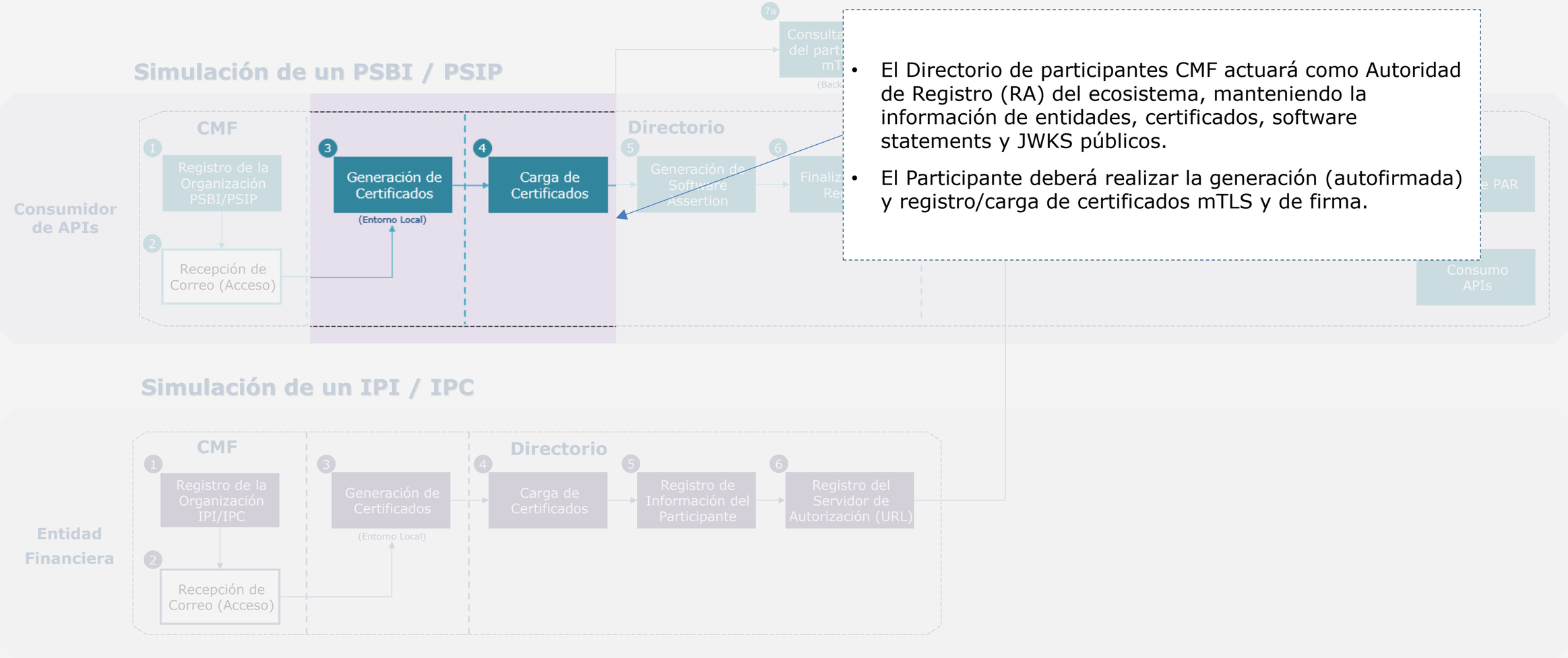


Diagrama de pasos y pruebas ATENA

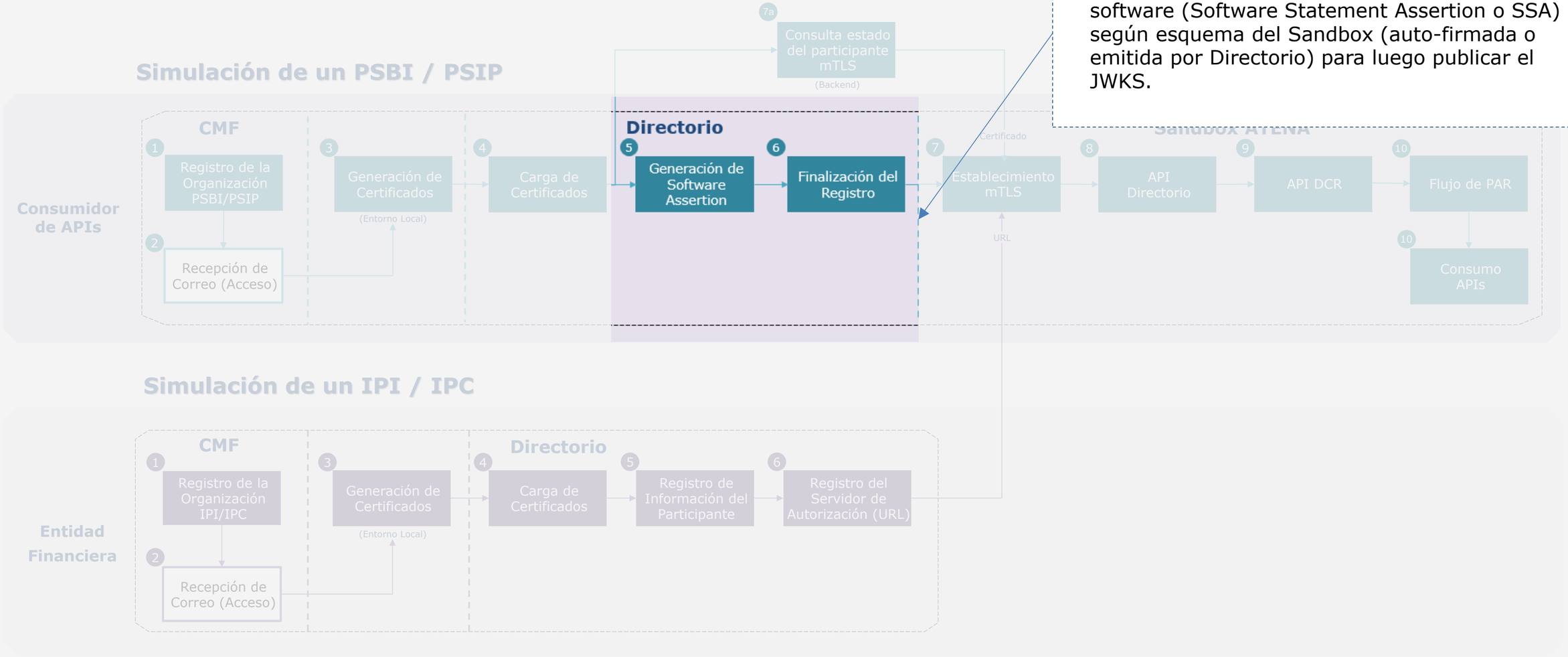
Diagrama de alto nivel



- El Directorio de participantes CMF actuará como Autoridad de Registro (RA) del ecosistema, manteniendo la información de entidades, certificados, software statements y JWKS públicos.
- El Participante deberá realizar la generación (autofirmada) y registro/carga de certificados mTLS y de firma.

Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel



- El Participante deberá generar la declaración de software (Software Statement Assertion o SSA) según esquema del Sandbox (auto-firmada o emitida por Directorio) para luego publicar el JWKS.

Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- Ejecutar Dynamic Client Registration: consultar /.well-known y registrar cliente en AS (POST /register) usando SSA.
- Con el certificado cargado, se buscará probar la conectividad y autenticación: handshake mTLS + flujo /authorize + /token.

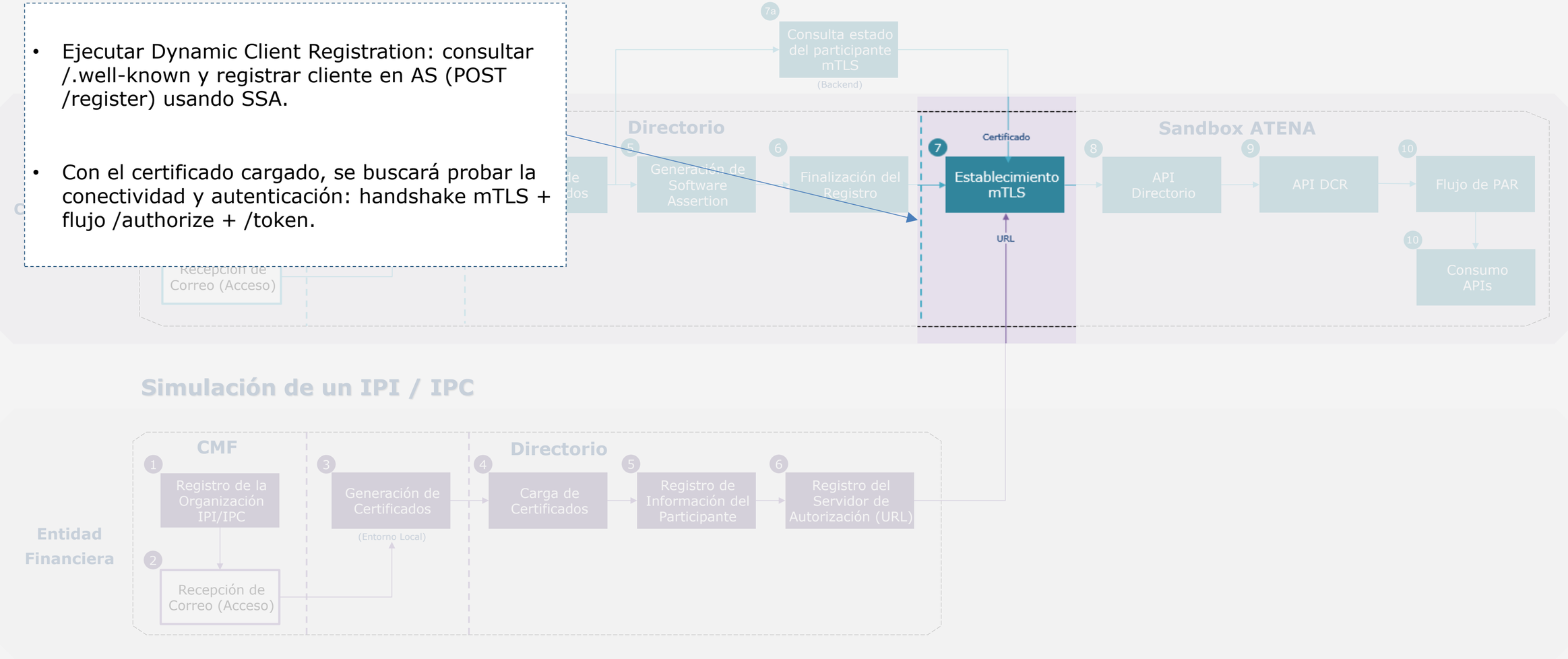


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- La IPI/IPC utiliza la información del certificado mTLS para validar el estatus de la PSBI/PSIP en el directorio. Si la PSBI tiene un status activo, le permitirá establecer la conexión mTLS. En caso de no estar activo, se rechaza.

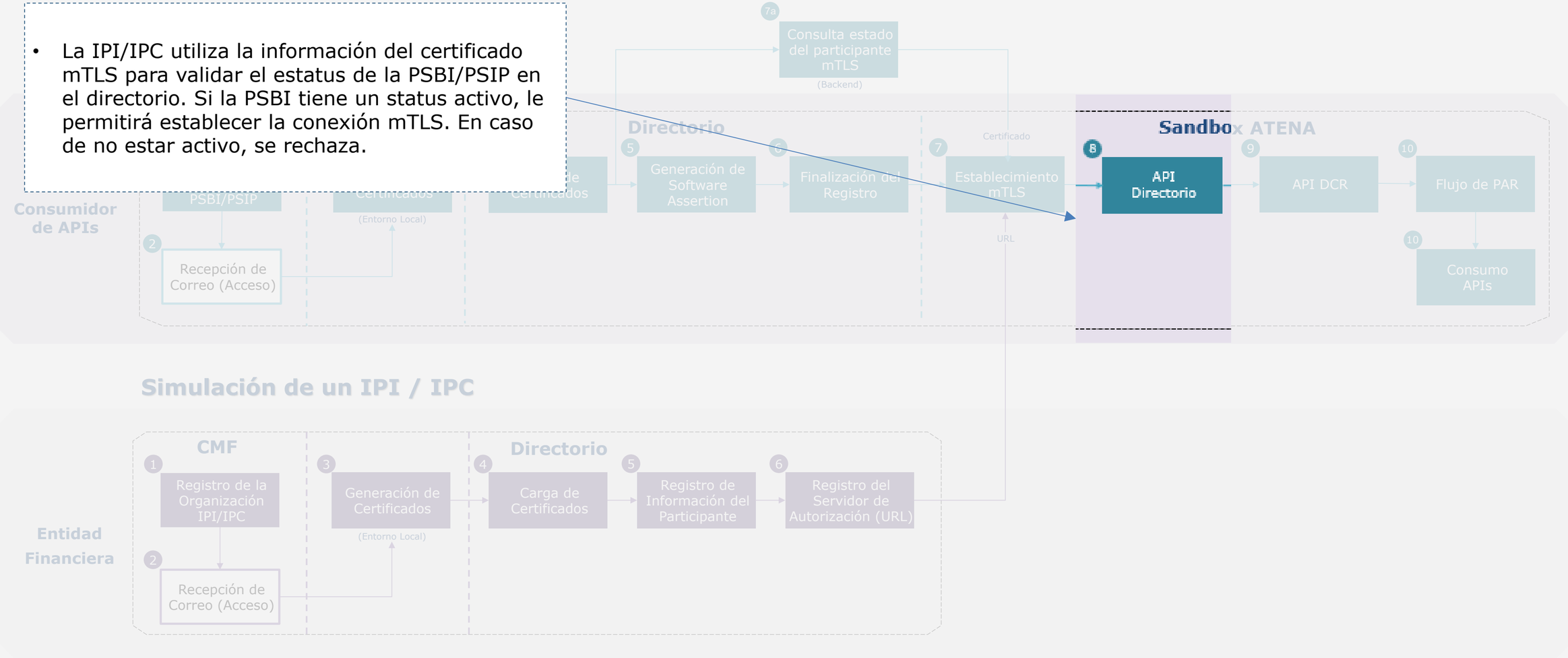


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- **API DCR**: Una vez establecida la conexión, la PSBI/PSIP podrá invocar la API DCR para realizar el registro en su servidor de autorización utilizando el software statement assertion (SSA) obtenido durante el proceso de registro en el directorio.
- El resultado de este registro le permite al PSBI/PSIP obtener un clientID que utilizará para realizar las invocaciones al Endpoint de PAR.
- **Flujo PAR**: Con el registro realizado, la PSBI/PSIP podrá realizar la creación de un consentimiento por medio del Endpoint de PAR y mediante el uso del Authorization Details para definir el alcance del consentimiento.
- Como resultado, se obtendrá un refresh token con el alcance del consentimiento autorizado por el usuario.

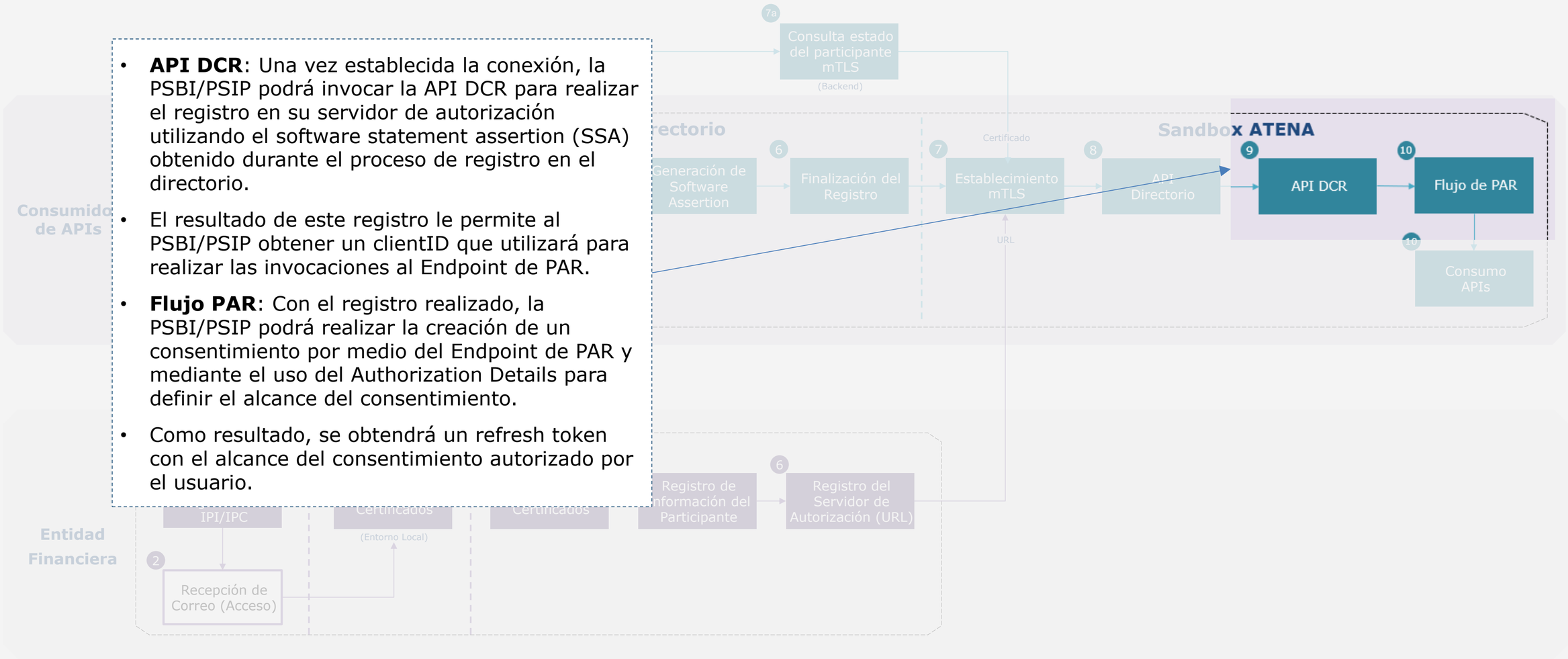


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- El Participante deberá realizar el consumo de APIs de SFA
  - API Open Data
  - API Productos y Transacciones
  - En el batch 3 se podrá probar las APIs de Iniciación de pago
- Podrán encontrar información con el manual de ejecución de pruebas y colecciones de Postman en el link https://openfinancechile.atlassian.net/wiki/spaces/OFAC/pages/292585512/Entidad+Financiera+Simulada+EFS#Manual-de-Consumo-de-APIs
- También podrán probar la API del Directorio para copia local y validaciones: /participants, /public-keys, /last-update.

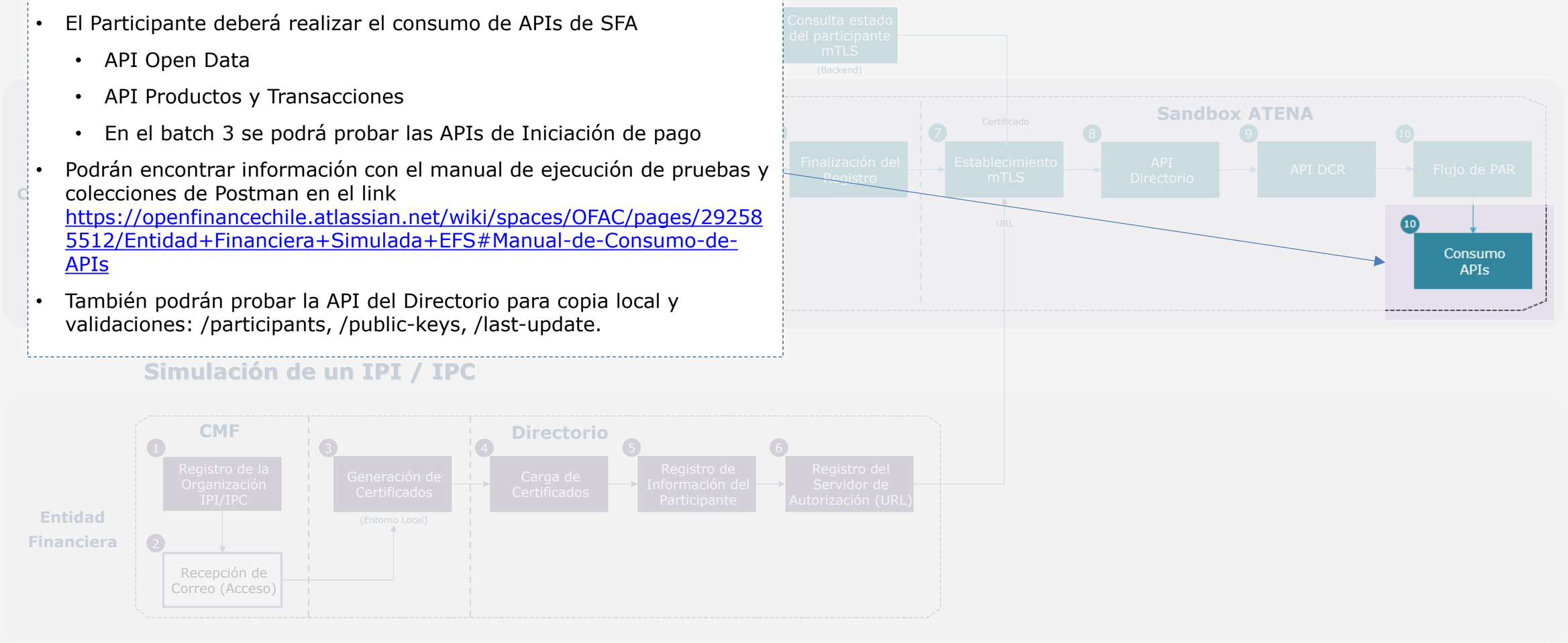


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- Para el flujo de una IPI/IPC, el primer paso es completar la información del Participante en el Directorio SFA
- El Participante deberá darse de alta en el Directorio pre-productivo en el siguiente link https://directorio-qa.finanzasabiertas.cl/auth/login

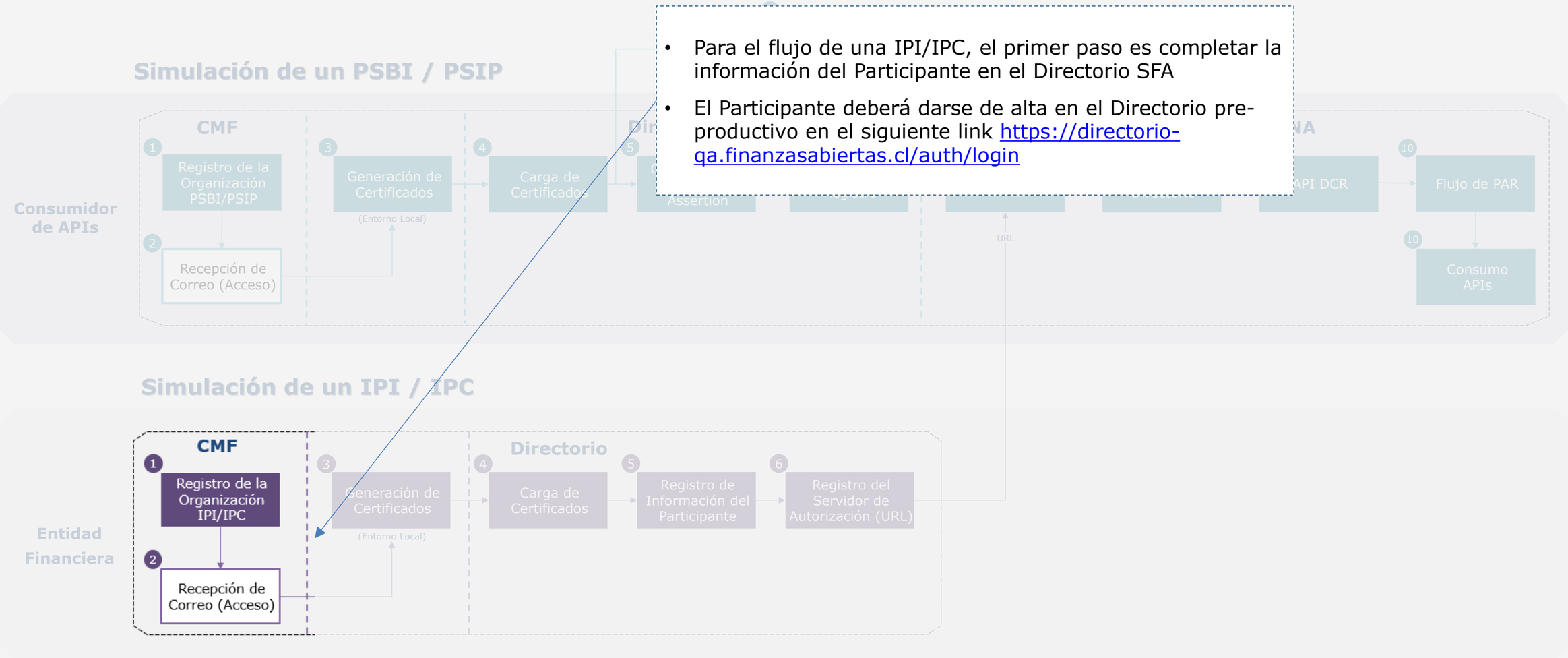


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- El Directorio de participantes CMF actuará como Autoridad de Registro (RA) del ecosistema, manteniendo la información de entidades, certificados, software statements y JWKS públicos.
- El Participante deberá realizar la generación (autofirmada) y registro/carga de certificados mTLS y de firma.

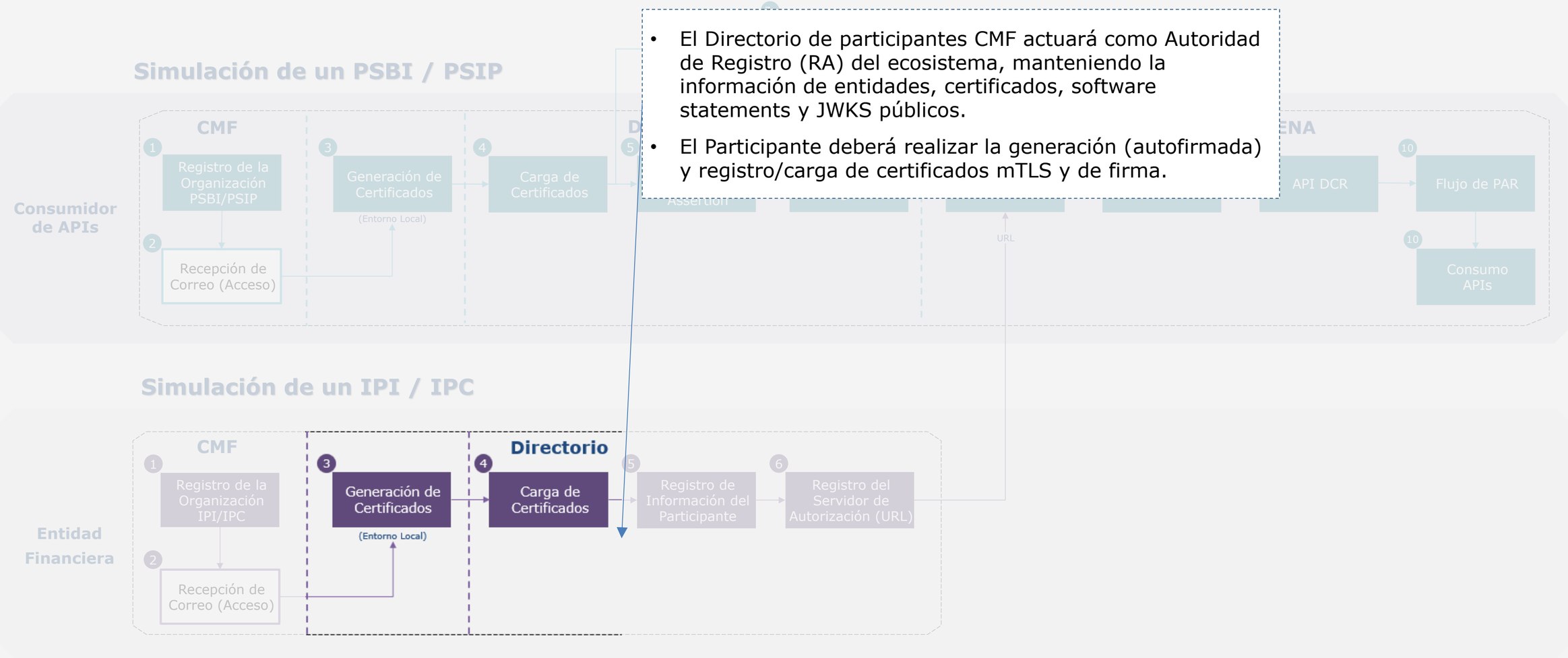
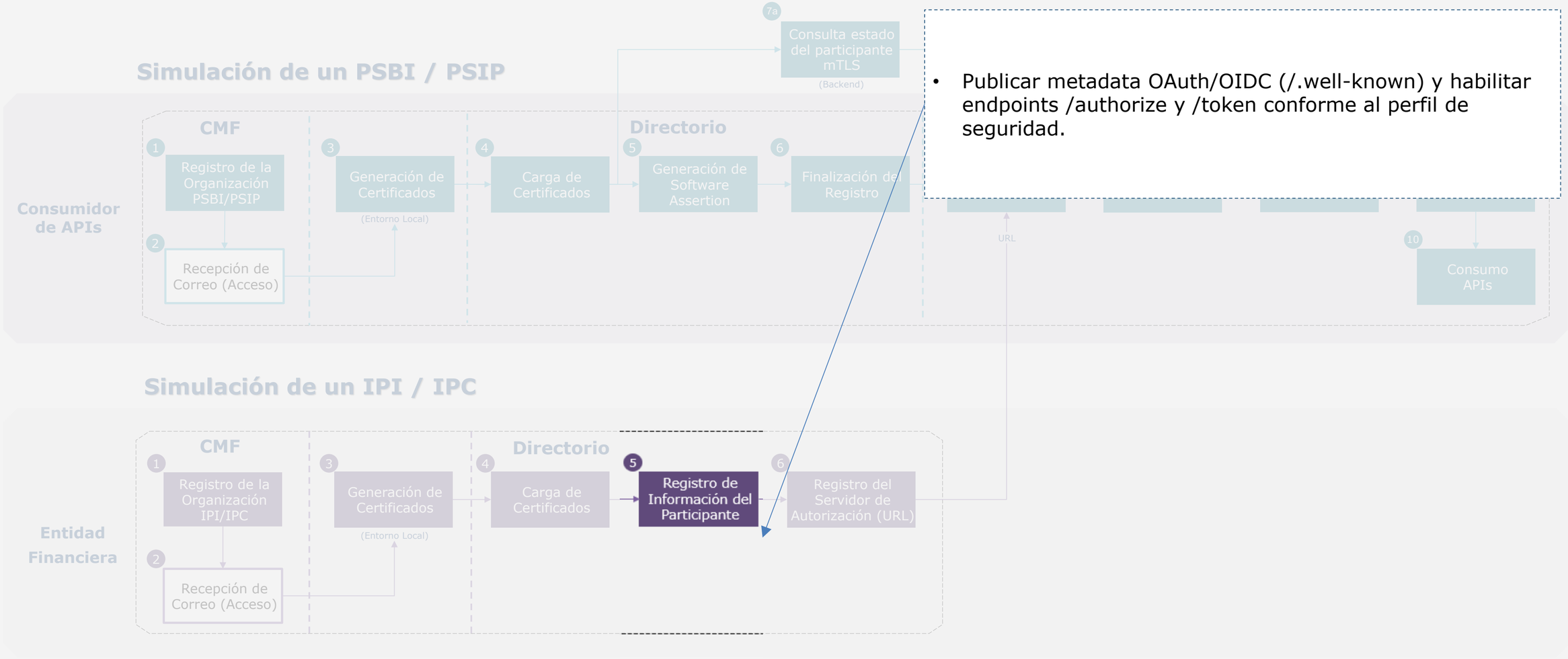


Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

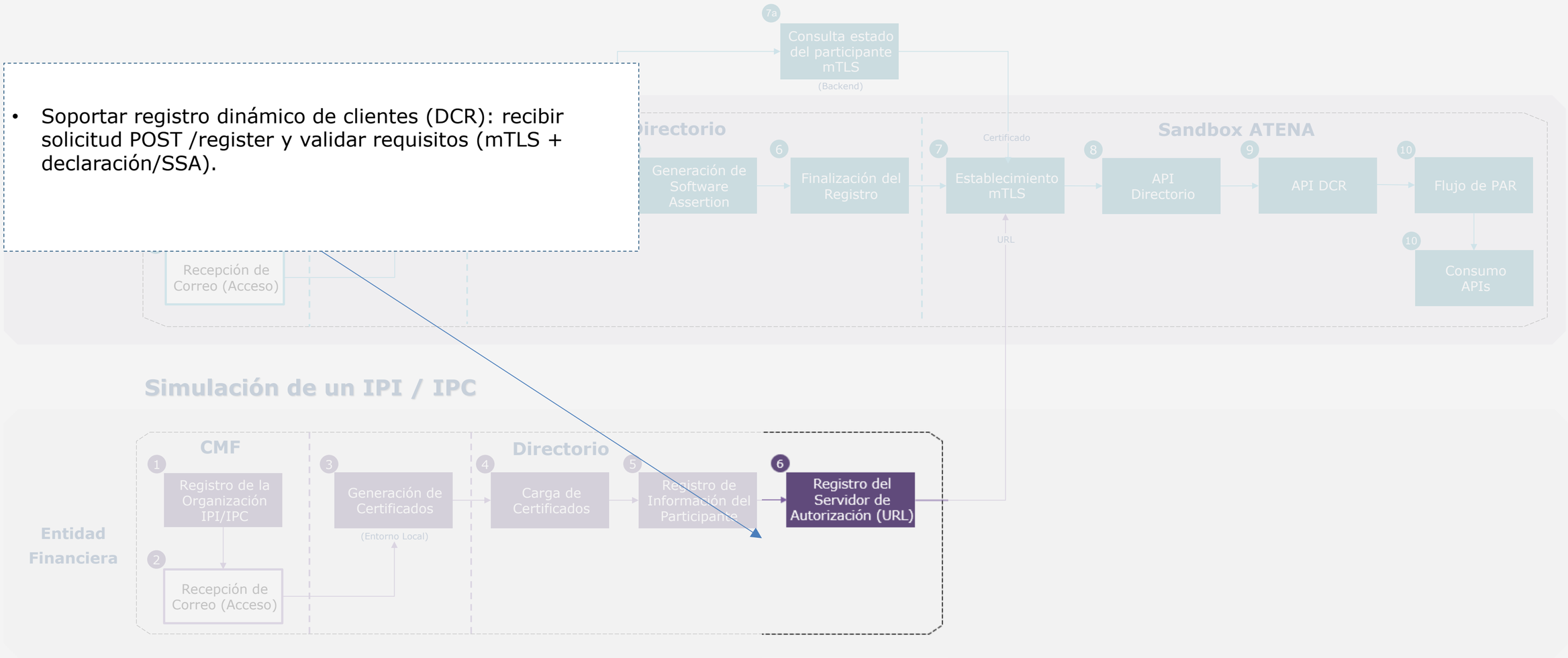


- Publicar metadata OAuth/OIDC (/.well-known) y habilitar endpoints /authorize y /token conforme al perfil de seguridad.

Diagrama de pasos y pruebas ATENA

Diagrama de alto nivel

- Soportar registro dinámico de clientes (DCR): recibir solicitud POST /register y validar requisitos (mTLS + declaración/SSA).



COMISIÓN PARA EL MERCADO FINANCIERO

Regulador y Supervisor Financiero de Chile

Guía de ayuda rápida para pruebas en Sandbox ATENA SFA

Ambiente Tecnológico de Experimentación y Nuevas Aplicaciones

finanzasabiertas

COMISIÓN PARA EL MERCADO FINANCIERO

Marzo 2026